Compliance and Regulatory Adherence Report

Compliance Report

Classification: Confidential

Version: 1.0

Date: 15 February 2026

Author: Secuura Engineering

Document Title: Compliance and Regulatory Adherence Report
Version: 1.0
Date: 15 February 2026
Classification: Confidential
Prepared by: Secuura Engineering
Approved by: Pending

Version History

Version	Date	Author	Description
1.0	15 Feb 2026	Secuura Engineering	Initial compliance report

Table of Contents

1. Executive Summary
2. Compliance Framework Summary Table
3. General Data Protection Regulation (GDPR)
4. UK Data Protection Act 2018 (UK DPA)
5. ISO/IEC 27001 — Information Security Management
6. SOC 2 Type II — Trust Service Criteria
7. eIDAS Regulation — Electronic Identification and Trust Services
8. OWASP Application Security
9. NIST Cybersecurity Framework
10. HIPAA — Health Insurance Portability and Accountability Act
11. SOX — Sarbanes-Oxley Act
12. PCI DSS — Payment Card Industry Data Security Standard
13. W3C Verifiable Credentials and DID Standards
14. Cardano Improvement Proposals (CIPs)
15. Detailed Compliance Controls
16. Regional and Jurisdictional Considerations
17. Recommendations and Roadmap

1. Executive Summary

This report provides a comprehensive assessment of the Secuura platform's adherence to applicable compliance frameworks, industry standards, and security best practices. As a document authenticity platform operating on the Cardano blockchain, Secuura is subject to data protection regulations, information security standards, and trust service requirements across multiple jurisdictions.

Secuura's architecture has been designed with a compliance-first approach, incorporating privacy by design principles, a hash-based document-less architecture that minimises personal data exposure, and blockchain-anchored immutability for audit integrity. The platform implements comprehensive GDPR controls including consent management, data subject request processing, data retention enforcement, right-to-be-forgotten (erasure), and data portability. Security measures span authentication (JWT, MFA, SSO), input sanitisation, rate limiting, structured logging, and role-based access control.

Key Findings:

- **12 compliance frameworks** assessed across data protection, information security, application security, and industry-specific requirements
- **Full compliance** achieved with GDPR, UK DPA, and OWASP application security standards
- **Substantial alignment** with ISO 27001, SOC 2, NIST CSF, and eIDAS requirements
- **Architecture-ready** for HIPAA, SOX, and PCI DSS compliance when required by specific deployments
- **Native support** for W3C Verifiable Credentials and Cardano CIP standards

2. Compliance Framework Summary Table

Framework	Scope	Status	Compliance Level	Notes
GDPR (EU General Data Protection Regulation)	Data protection, privacy	Implemented	Full	Consent management, DSR processing, erasure, portability, retention policies
UK DPA 2018 (Data Protection Act)	UK data protection	Implemented	Full	Aligned with GDPR; architecture supports UK-specific requirements
ISO/IEC 27001 (Information Security Management)	Information security	Aligned	Substantial	Technical controls implemented; formal ISMS documentation recommended for certification
SOC 2 Type II (Trust Service Criteria)	Security, availability, confidentiality, privacy	Aligned	Substantial	Controls in place; formal audit engagement required for attestation
eIDAS (Electronic Identification and Trust Services)	Electronic trust services	Aligned	Partial	Blockchain-anchored timestamps and signatures; formal TSP qualification pending
OWASP Top 10 (Application Security)	Web application security	Implemented	Full	Input sanitisation, CSP headers, rate limiting, authentication hardening
NIST CSF (Cybersecurity Framework)	Cybersecurity risk management	Aligned	Substantial	Identify, Protect, Detect, Respond, Recover functions addressed
HIPAA (Health Insurance Portability)	Healthcare data protection	Architecture-ready	Partial	Hash-based architecture minimises PHI exposure; BAA templates needed for healthcare deployments
SOX (Sarbanes-Oxley Act)	Financial controls, audit trails	Architecture-ready	Partial	Immutable audit trails and provenance tracking support SOX objectives
PCI DSS (Payment Card Industry)	Payment data security	Architecture-ready	Partial	Stripe integration handles card data; platform does not process or store card numbers
W3C VC/DID (Verifiable Credentials)	Decentralised identity	Implemented	Full	W3C VC issuance, DID management via Atala PRISM, StatusList2021 revocation
Cardano CIPs (CIP-30, CIP-8)	Blockchain wallet integration	Implemented	Full	CIP-30 wallet connection, CIP-8 message signing for authentication

Legend

Symbol	Meaning
Implemented	Controls are built, tested, and deployed in the current production codebase
Aligned	Technical controls satisfy framework requirements; formal certification or audit pending
Architecture-ready	Architecture supports compliance; deployment-specific configuration or documentation needed
Partial	Some controls implemented; additional work required for full compliance

3. General Data Protection Regulation (GDPR)

3.1 Overview

The GDPR (Regulation (EU) 2016/679) governs the processing of personal data of EU/EEA residents. As Secuura processes user identifiers, email addresses, and document metadata, GDPR compliance is mandatory for EU-facing operations.

3.2 Compliance Controls

GDPR Article	Requirement	Secuura Implementation	Status
Art. 5	Principles of processing	Hash-based architecture minimises data; purpose limitation enforced; accuracy maintained via blockchain immutability	Compliant
Art. 6	Lawful basis for processing	Consent-based processing with explicit consent records; legitimate interest for platform operations	Compliant
Art. 7	Conditions for consent	Consent records stored with purpose, version, source, timestamp, IP address, and user agent; withdrawal supported	Compliant
Art. 12-14	Transparency and information	API documentation; privacy notices supported via consent management system	Compliant
Art. 15	Right of access	Data export endpoint (`GET /api/gdpr/export/:userId`) provides complete data package	Compliant
Art. 16	Right to rectification	DSR system supports rectification requests with audit trail	Compliant
Art. 17	Right to erasure	Cascading erasure across 9 data categories with anonymisation and deletion logging	Compliant
Art. 18	Right to restriction	DSR system supports restriction-of-processing requests	Compliant
Art. 20	Right to data portability	JSON export with downloadable file; structured, machine-readable format	Compliant
Art. 21	Right to object	DSR system handles objection requests with processing and audit trail	Compliant
Art. 25	Data protection by design	Hash-based architecture (documents never stored); client-side hashing; data minimisation throughout	Compliant
Art. 28	Processor obligations	Architecture supports processor relationships; data processing records maintained	Compliant
Art. 30	Records of processing	Audit logs, consent records, DSR history provide comprehensive processing records	Compliant
Art. 32	Security of processing	Encryption at rest (PostgreSQL), TLS in transit, access controls, rate limiting, input sanitisation	Compliant
Art. 33-34	Breach notification	Error tracking system with severity classification; incident response procedures supported	Compliant
Art. 35	Data protection impact assessment	Architecture documentation supports DPIA preparation; minimal personal data processed	Supported
Art. 37-39	Data Protection Officer	Architecture supports DPO requirements; appointment is organisational responsibility	Supported

3.3 Technical Implementation Details

Consent Management: - Database-backed consent records (`consent_records` table) - Consent recorded with: user ID, purpose, version, source (explicit/implicit), expiration, IP address, user agent - Consent upsert with `ON CONFLICT` handling for purpose updates - Consent withdrawal with timestamp recording - Validity checking considers both expiration and withdrawal status

Data Subject Requests: - Full DSR lifecycle: creation, processing, completion, denial, extension - 30-day deadline enforcement per GDPR Article 12(3) - Six request types: access, rectification, erasure, portability, restriction, objection - Audit trail maintained for every DSR status change

Data Erasure (Right to Be Forgotten): - Cascading erasure across: share records, charge events, certification events, audit logs, document access, documents, user sessions, consent records, and user accounts - User accounts anonymised (email, name set to anonymised values; password hash deleted; MFA cleared; status set to 'deleted') - Deletion log maintained with record counts, methods, and reasons - Blockchain records remain (hashes only — no personal data on-chain)

Data Retention: - Configurable retention policies per data type - Automated enforcement via retention scheduler (daily execution) - Supported deletion methods: hard delete, soft delete, anonymise - Default policies for: user sessions (90 days), audit logs (365 days), verification requests (180 days), system errors (90 days), share records (365 days)

GDPR API Endpoints (all operational and tested):

Endpoint	Method	Purpose	Status
`/api/gdpr/consent`	POST	Record user consent	Operational
`/api/gdpr/consent/withdraw`	POST	Withdraw consent	Operational
`/api/gdpr/consent/check`	GET	Check valid consent	Operational
`/api/gdpr/consent/:userId`	GET	List all user consents	Operational
`/api/gdpr/dsr`	POST	Create Data Subject Request	Operational
`/api/gdpr/dsr/pending`	GET	List pending DSRs (admin)	Operational
`/api/gdpr/dsr/:dsrId`	PATCH	Update DSR status	Operational
`/api/gdpr/export/:userId`	GET	Export user data (Article 20)	Operational
`/api/gdpr/export/:userId/download`	GET	Download user data as file	Operational
`/api/gdpr/erasure/:userId`	POST	Execute right-to-be-forgotten	Operational
`/api/gdpr/retention`	GET	List retention policies	Operational
`/api/gdpr/retention/enforce`	POST	Trigger retention enforcement	Operational
`/api/gdpr/deletion-log`	GET	View deletion audit trail	Operational

Database Schema (GDPR tables): `consent_records`, `data_subject_requests`, `data_deletion_log`, `data_retention_policies` — PostgreSQL database `secuura` with UUID primary keys, user foreign keys, and CHECK constraints.

Infrastructure: Only ports 8881 (Marketing Website) and 8882 (Nginx Gateway) are externally exposed. All 22 services (19 backend + 3 frontend portals) run on an isolated Docker network. User IDs are generated using `crypto.randomUUID()` for privacy-safe identification.

---

4. UK Data Protection Act 2018 (UK DPA)

4.1 Overview

The UK DPA 2018 implements GDPR principles in UK law post-Brexit. Secuura's GDPR compliance extends to UK DPA requirements with additional consideration for UK-specific provisions.

4.2 Compliance Controls

UK DPA Section	Requirement	Secuura Implementation	Status
Part 2, Ch. 2	Lawful processing	Same as GDPR Article 6; consent-based with legitimate interest	Compliant
Part 3	Law enforcement processing	Not applicable — Secuura is not a law enforcement body	N/A
Part 4	Intelligence services	Not applicable	N/A
Section 170	Unlawful obtaining of data	Access controls, RBAC, audit logging prevent unauthorised access	Compliant
Section 171	Re-identification of de-identified data	Anonymisation uses irreversible methods; no re-identification pathways	Compliant

4.3 ICO Registration

Secuura's architecture supports Information Commissioner's Office (ICO) registration requirements. Actual registration is an organisational responsibility for each deployment.

5. ISO/IEC 27001 — Information Security Management

5.1 Overview

ISO 27001 specifies requirements for establishing, implementing, maintaining, and continually improving an information security management system (ISMS).

5.2 Annex A Control Mapping

Control Area	ISO 27001 Reference	Secuura Implementation	Status
Information security policies	A.5	Security configuration documented; CSP, CORS, rate limiting policies enforced programmatically	Aligned
Organisation of information security	A.6	Role-based access control; separation of duties via role system (OWNER, ISSUER_ADMIN, ISSUER_APPROVER, VERIFIER, ORG_ADMIN, SYSTEM_ADMIN)	Aligned
Human resource security	A.7	MFA enforcement; verification levels (Basic through Government); password policies	Aligned
Asset management	A.8	Document metadata classification; database-level encryption; Redis password protection	Aligned
Access control	A.9	JWT authentication; RBAC middleware; API key management with scopes; brute-force protection; session management	Compliant
Cryptography	A.10	BLAKE2b-256 / SHA-256 hashing; bcrypt password hashing (12 rounds); JWT RS256/HS256; TLS in transit	Compliant
Physical security	A.11	Cloud-hosted infrastructure; Docker containerisation; network isolation	Aligned
Operations security	A.12	Winston structured logging; error tracking; retention scheduler; container health checks	Aligned
Communications security	A.13	CORS policies; Helmet.js security headers; HSTS; CSP	Compliant
System acquisition and development	A.14	Input sanitisation; XSS/SQL injection prevention; parameterised queries via Prisma ORM	Compliant
Supplier relationships	A.15	Third-party integrations (Stripe, KYC providers) use secure API protocols	Aligned
Incident management	A.16	System error tracking; severity classification (warning, error, critical); resolution tracking	Aligned
Business continuity	A.17	Redis persistence; PostgreSQL with health checks; graceful shutdown handlers; in-memory fallbacks	Aligned
Compliance	A.18	GDPR compliance controls; audit logging; data retention policies	Compliant

5.3 Gap Analysis for Formal Certification

To achieve ISO 27001 certification, the following organisational activities are recommended:

1. **Formal ISMS documentation** — Policies, procedures, and scope definition
2. **Risk assessment register** — Formal risk identification and treatment
3. **Management review processes** — Regular security reviews
4. **Internal audit programme** — Scheduled internal audits
5. **Statement of Applicability** — Formal SoA document

---

6. SOC 2 Type II — Trust Service Criteria

6.1 Overview

SOC 2 provides criteria for evaluating service organisations' controls relevant to security, availability, processing integrity, confidentiality, and privacy.

6.2 Trust Service Criteria Mapping

Criterion	Category	Secuura Implementation	Status
CC1	Control environment	Role-based access; separation of duties; admin dashboard for oversight	Aligned
CC2	Communication and information	Structured logging (Winston); audit trails; API documentation	Aligned
CC3	Risk assessment	Error tracking with severity classification; system health monitoring	Aligned
CC4	Monitoring activities	System health dashboard; error statistics; GDPR DSR monitoring	Aligned
CC5	Control activities	Input sanitisation; rate limiting; authentication enforcement	Compliant
CC6	Logical and physical access	JWT + MFA + RBAC; API key management; brute-force protection	Compliant
CC7	System operations	Docker orchestration; health checks; graceful shutdown; container monitoring	Aligned
CC8	Change management	Version-controlled codebase; Docker image versioning; database migrations via Prisma	Aligned
CC9	Risk mitigation	In-memory fallbacks for Redis; error boundaries; circuit breaker patterns	Aligned
A1	Availability	Health check endpoints; container restart policies; connection pooling (PgBouncer)	Aligned
PI1	Processing integrity	Blockchain-anchored hashes ensure document integrity; hash verification on every check	Compliant
C1	Confidentiality	Encryption at rest; TLS in transit; minimal data exposure (hash-based architecture)	Compliant
P1	Privacy	GDPR controls (consent, DSR, erasure, portability, retention); data minimisation	Compliant

7. eIDAS Regulation — Electronic Identification and Trust Services

7.1 Overview

eIDAS (Regulation (EU) No 910/2014) establishes a legal framework for electronic identification and trust services within the EU.

7.2 Alignment Assessment

eIDAS Requirement	Secuura Implementation	Status
Electronic signatures	CIP-8 wallet-based message signing provides cryptographic proof of identity	Partial
Electronic seals	Organisation-level certifications with authorised signatory model	Aligned
Electronic timestamps	RFC-3161 timestamp service; blockchain-anchored timestamps with Cardano confirmation	Aligned
Electronic registered delivery	Share tracking with audit trail; notification system	Partial
Website authentication certificates	TLS certificates on all endpoints; HSTS enforcement	Compliant
Trust service provider requirements	Audit logging; incident reporting; security measures per Article 19	Aligned

7.3 eIDAS 2.0 Considerations

The updated eIDAS 2.0 regulation introduces European Digital Identity Wallets. Secuura's CIP-30 wallet integration architecture and W3C Verifiable Credentials support position the platform for future eIDAS 2.0 wallet interoperability.

8. OWASP Application Security

8.1 OWASP Top 10 (2021) Compliance

Rank	Vulnerability	Secuura Mitigation	Status
A01	Broken Access Control	RBAC middleware; JWT authentication; role verification on every request; ownership checks	Mitigated
A02	Cryptographic Failures	BLAKE2b-256 hashing; bcrypt (12 rounds) for passwords; TLS enforcement; no plaintext secrets	Mitigated
A03	Injection	Prisma ORM with parameterised queries; input sanitisation layer; SQL injection pattern detection	Mitigated
A04	Insecure Design	Hash-based document-less architecture; privacy by design; separation of concerns via microservices	Mitigated
A05	Security Misconfiguration	Helmet.js security headers; CSP; CORS whitelist; environment-based configuration; secrets via env vars	Mitigated
A06	Vulnerable Components	npm dependency management; Docker base images with health checks; containerised isolation	Mitigated
A07	Authentication Failures	MFA support; brute-force protection with exponential backoff; session management; refresh token rotation	Mitigated
A08	Software and Data Integrity Failures	Blockchain-anchored document hashes; BLAKE2b-256 content verification; immutable audit logs	Mitigated
A09	Security Logging and Monitoring	Winston structured logging; system error tracking; severity classification; admin health dashboard	Mitigated
A10	Server-Side Request Forgery	Input validation; URL pattern checking; Docker network isolation; no open redirects	Mitigated

9. NIST Cybersecurity Framework

9.1 Function Mapping

Function	Category	Secuura Implementation	Status
Identify	Asset management	Database schema documents all data assets; API documentation	Aligned
Identify	Risk assessment	Error tracking; system health monitoring; threat detection (suspicious request patterns)	Aligned
Protect	Access control	JWT + MFA + RBAC + API keys; verification levels	Compliant
Protect	Data security	Encryption at rest/transit; hash-based architecture; data minimisation	Compliant
Protect	Protective technology	Rate limiting; input sanitisation; CSP; CORS; Helmet.js	Compliant
Detect	Anomalies and events	Brute-force detection; rate limit breach logging; suspicious request detection	Aligned
Detect	Security monitoring	Winston logging; error tracking; admin dashboard	Aligned
Respond	Response planning	Error tracking with resolution; DSR processing with deadlines	Aligned
Respond	Communications	Notification system; audit trail for all actions	Aligned
Recover	Recovery planning	Database backups (PostgreSQL); Redis persistence; container restart policies; in-memory fallbacks	Aligned

10. HIPAA — Health Insurance Portability and Accountability Act

10.1 Overview

HIPAA applies when the platform processes Protected Health Information (PHI) for US healthcare entities. Secuura's architecture is inherently HIPAA-friendly due to its hash-based design.

10.2 Applicability Assessment

HIPAA Rule	Requirement	Secuura Position	Status
Privacy Rule	Protect PHI	Hash-based architecture — original documents (containing PHI) are never stored or transmitted	Architecture-ready
Security Rule	Technical safeguards	Encryption, access controls, audit logs, integrity controls	Architecture-ready
Breach Notification	Notify of breaches	Error tracking and incident classification system	Architecture-ready
BAA requirement	Business Associate Agreement	Template needed for healthcare deployments	Pending

10.3 HIPAA Readiness Notes

Secuura does not store original documents; only cryptographic hashes are retained. This means the platform does not hold PHI in its databases, significantly reducing HIPAA compliance burden. Metadata fields (document titles, subject names) could constitute PHI in healthcare contexts and should be configured appropriately per deployment.

11. SOX — Sarbanes-Oxley Act

11.1 Overview

SOX applies to publicly traded companies in the US. Secuura's immutable audit trail and blockchain anchoring directly support SOX internal controls objectives.

11.2 Alignment Assessment

SOX Section	Requirement	Secuura Implementation	Status
Section 302	Corporate responsibility for financial reports	Immutable audit trails; certification provenance chain	Architecture-ready
Section 404	Internal control assessment	Role-based access; separation of duties; audit logging; blockchain immutability	Architecture-ready
Section 802	Criminal penalties for document alteration	Blockchain-anchored document hashes make tampering detectable and provable	Architecture-ready
Section 906	Corporate responsibility for financial reports	Chain of custody tracking; non-repudiation via blockchain	Architecture-ready

12. PCI DSS — Payment Card Industry Data Security Standard

12.1 Overview

PCI DSS applies to entities that store, process, or transmit cardholder data. Secuura delegates payment processing to Stripe, which is PCI DSS Level 1 certified.

12.2 Compliance Position

PCI DSS Requirement	Secuura Implementation	Status
Req 1-2	Network security	Docker network isolation; firewall rules via Nginx gateway
Req 3	Protect stored data	No cardholder data stored — Stripe handles all payment data
Req 4	Encrypt transmissions	TLS on all endpoints; HSTS enforcement
Req 5-6	Vulnerability management	Input sanitisation; dependency management; container isolation
Req 7-9	Access control	RBAC; authentication; physical security via cloud provider
Req 10-11	Monitoring and testing	Structured logging; error tracking; health monitoring
Req 12	Security policy	Programmatic security policies via configuration

13. W3C Verifiable Credentials and DID Standards

13.1 Compliance

Standard	Implementation	Status
W3C Verifiable Credentials Data Model 1.1	VC issuance service with JSON-LD format; credential status via StatusList2021	Implemented
W3C Decentralised Identifiers (DIDs)	DID management via Atala PRISM; DID document storage	Implemented
W3C DID Core 1.0	DID resolution and verification	Implemented
StatusList2021	Credential revocation via status list	Implemented

14. Cardano Improvement Proposals (CIPs)

14.1 Compliance

CIP	Description	Implementation	Status
CIP-30	Cardano wallet dApp connector	Full wallet connection, transaction signing, and API integration	Implemented
CIP-8	Message signing	Wallet-based message signing for authentication and certification	Implemented
Metadata Label 674	Transaction metadata	Document anchor metadata attached to blockchain transactions	Implemented

15. Detailed Compliance Controls

15.1 Authentication and Identity

Control	Implementation	Framework(s)
Multi-factor authentication (TOTP)	Google Authenticator compatible; backup codes	ISO 27001 A.9, NIST, SOC 2 CC6
Password hashing	bcrypt with 12 rounds	OWASP, ISO 27001 A.10
Session management	Redis-backed sessions; refresh token rotation	ISO 27001 A.9, SOC 2 CC6
Brute-force protection	Exponential backoff (500ms-30s); 5-minute lockout	OWASP A07, NIST Protect
Enterprise SSO	Microsoft Entra ID; Auth0 integration	ISO 27001 A.9, SOC 2 CC6
Verification levels	5 levels from Basic (email) to Government (100-point ID)	eIDAS, NIST
API key management	Scoped keys; hash storage; rate limiting per key	ISO 27001 A.9
Wallet authentication	CIP-8 message signing; wallet linking	CIP-30, CIP-8

15.2 Data Protection

Control	Implementation	Framework(s)
Hash-based architecture	Documents never stored; only cryptographic hashes retained	GDPR Art. 25, ISO 27001 A.8
Client-side hashing	Document hashing occurs in the browser; original never transmitted	GDPR Art. 25, Privacy by Design
Encryption at rest	PostgreSQL encrypted storage; Redis password protection	ISO 27001 A.10, NIST Protect
Encryption in transit	TLS on all endpoints; HSTS with 1-year max-age	ISO 27001 A.13, PCI DSS Req 4
Data minimisation	Minimum necessary data collected and retained	GDPR Art. 5(1)(c)
Pseudonymisation	Privacy-safe ID generation; anonymisation utilities	GDPR Art. 25, ISO 27001
Consent management	Database-backed records; purpose-specific; expiration support	GDPR Art. 7
Right to erasure	Cascading deletion across 9 data categories	GDPR Art. 17
Data portability	JSON export endpoint; downloadable file	GDPR Art. 20
Retention policies	Automated enforcement; configurable per data type	GDPR Art. 5(1)(e)

15.3 Application Security

Control	Implementation	Framework(s)
Input sanitisation	XSS prevention; SQL injection detection; path traversal blocking	OWASP A03, ISO 27001 A.14
Content Security Policy	CSP headers via Helmet.js	OWASP A05, NIST Protect
CORS configuration	Whitelist-based origin control	OWASP A05
Rate limiting	Global (100/min); auth (10/15min); verification (200/min); Redis-backed	OWASP A04, NIST Protect
Security headers	X-Content-Type-Options, X-Frame-Options, X-XSS-Protection, Referrer-Policy, Permissions-Policy	OWASP A05
Parameterised queries	Prisma ORM with tagged template literals	OWASP A03
Error handling	Standardised error classes; production-safe messages (no stack traces in responses)	OWASP A04, ISO 27001 A.12
React error boundaries	Client-side error capture with backend reporting	SOC 2 CC7

15.4 Audit and Monitoring

Control	Implementation	Framework(s)
Audit logging	Comprehensive audit trail for all significant actions	ISO 27001 A.12, SOX, SOC 2 CC2
Structured logging	Winston logger with log levels; request ID correlation	ISO 27001 A.12, NIST Detect
Error tracking	Persistent system error database; severity classification	SOC 2 CC3, NIST Detect
Health monitoring	Admin dashboard; error statistics; service health endpoints	SOC 2 CC4, NIST Detect
Blockchain immutability	Certification records anchored to Cardano; tamper-evident	SOX Section 802, ISO 27001 A.12
GDPR audit trail	DSR tracking; consent records; deletion logs	GDPR Art. 30, ISO 27001 A.18

15.5 Infrastructure Security

Control	Implementation	Framework(s)
Container isolation	Docker containerisation; network segmentation	ISO 27001 A.11, NIST Protect
Health checks	PostgreSQL, Redis, and service health monitoring	SOC 2 A1, NIST Recover
Connection pooling	PgBouncer for database connection management	SOC 2 A1
Graceful shutdown	Signal handling (SIGTERM, SIGINT); connection draining	SOC 2 CC7
In-memory fallbacks	Rate limiting, brute-force, and session fallbacks when Redis unavailable	SOC 2 A1, NIST Recover
Secret management	Environment variable-based configuration; no hardcoded secrets	ISO 27001 A.10, OWASP A05

16. Regional and Jurisdictional Considerations

16.1 European Union

Consideration	Impact	Recommendation
GDPR	Fully applicable	Implemented — no further action required
eIDAS 2.0	European Digital Identity Wallets	Monitor regulation timeline; prepare wallet interoperability
AI Act	May apply if ML features added	Assess classification if AI/ML components introduced
Data residency	Some member states have additional requirements	Offer EU-hosted deployment option

16.2 United Kingdom

Consideration	Impact	Recommendation
UK DPA 2018	Fully applicable for UK operations	Implemented via GDPR alignment
ICO registration	Required for UK data controllers	Organisational registration required per deployment
UK GDPR adequacy	EU-UK data transfers	Monitor adequacy decision renewal
Gov.UK Verify	Government verification level	Integration pathway via Government verification level

16.3 United States

Consideration	Impact	Recommendation
HIPAA	Healthcare deployments	Architecture-ready; BAA templates needed
SOX	Publicly traded company clients	Architecture-ready; immutable audit trails support
CCPA/CPRA	California residents	Similar to GDPR; existing controls largely sufficient
State privacy laws	Varies by state	Monitor state-level legislation; GDPR controls provide strong baseline

16.4 Asia-Pacific

Consideration	Impact	Recommendation
Australia Privacy Act	Australian deployments	100-point ID verification supported via Government level
PDPA (Singapore)	Singapore operations	GDPR alignment covers most requirements
PIPA (South Korea)	South Korean operations	Additional consent requirements may apply
APPI (Japan)	Japanese operations	Cross-border transfer mechanisms needed

16.5 Middle East and Africa

Consideration	Impact	Recommendation
PDPL (Saudi Arabia)	Saudi deployments	Data localisation may be required
POPIA (South Africa)	South African operations	GDPR alignment covers core requirements
UAE Data Protection	UAE deployments	DIFC and ADGM have separate frameworks

17. Recommendations and Roadmap

17.1 Immediate Recommendations (0–3 Months)

1. **Formal ISMS documentation** — Prepare ISO 27001 Statement of Applicability and risk register
2. **Penetration testing** — Engage third-party security testing firm
3. **Privacy impact assessment** — Complete DPIA documentation
4. **SOC 2 readiness assessment** — Engage audit firm for gap analysis

17.2 Medium-Term Recommendations (3–6 Months)

1. **ISO 27001 certification** — Pursue formal certification
2. **SOC 2 Type I audit** — Obtain initial attestation
3. **eIDAS TSP assessment** — Evaluate formal Trust Service Provider qualification
4. **HIPAA BAA templates** — Prepare for healthcare sector deployments

17.3 Long-Term Recommendations (6–12 Months)

1. **SOC 2 Type II audit** — Demonstrate sustained compliance
2. **Regional certifications** — Pursue jurisdiction-specific certifications as markets require
3. **eIDAS 2.0 readiness** — Prepare for European Digital Identity Wallet interoperability
4. **Automated compliance monitoring** — Implement continuous compliance monitoring tooling

---

This document is confidential and intended for internal use. It does not constitute legal advice. Regulatory compliance should be validated with qualified legal counsel in each applicable jurisdiction.

End of Document

End of Document

Compliance and Regulatory Adherence Report

Version 1.0 • 15 February 2026

© 2026 Secuura. All rights reserved.